Commerce

Data Protection & Transfer Impact Summary

This document provides a summary of Commerce's data protection and transfer practices. It is not legal advice and does not provide an exhaustive list of the protections maintained by Commerce. The information provided is Commerce confidential and proprietary information and may be shared only: (i) in relation to a legitimate business purpose; and (ii) subject to an appropriate confidentiality expectation or obligation.

- Commerce maintains substantial infrastructure and platform data security safeguards. A summary of safeguards and how they contribute to the integrity of the Commerce platform is available in the Commerce Infrastructure & Platform Security Guide Whitepaper, with additional resources for merchants available on the Commerce Platform Trust Center. Commerce's safeguards include but are not limited to:
    - *Encryption.* Commerce encrypts your data by default, in-transit and at-rest.
    - *Security & Penetration Testing.* Commerce engages third-party providers to regularly conduct penetration tests and vulnerability assessments. Commerce also empowers any security researcher to test the platform's security by participating in a bug-bounty program.
    - *24/7 Cybersecurity.* Commerce's secure-by-design infrastructure includes perimeter and host-based firewalls, file integrity monitoring, intrusion detection, application firewalls and 24/7 monitoring by a global team. It also promotes resilience by replicating stores across spatially separated data centers, and disaster recovery by backing up production servers to remote storage locations.
    - *Minimisation of Personal Data.* Commerce strives to minimise personal data collected by its platform. To the extent practicable, Commerce also takes measures to anonymise, pseudonymise, tokenise, aggregate, and/or deidentify personal data consistent with Article 25 of GDPR.
- Consistent with Article 32 of GDPR, Commerce maintains a comprehensive Information Security Management System (ISMS), as well as a Privacy Information Management System (PIMS) and Business Continuity Management System (BCMS). Commerce's ISMS is audited annually by an independent third-party and certified as meeting or exceeding International Organization for Standardization's ISO/IEC 27001 standards.
    - Commerce's current ISO 27001 certification is available here.
    - Additional third-party reports detailing Commerce's technical and organizational controls include:
        - Commerce's SOC3 Report
        - Commerce's PCI-DSS Level 1 Merchant & Service-Provider AOCs
        - Commerce's SOC1 Report and SOC2 Report. These reports are not

publicly available for security reasons and may be subject to increased confidentiality or access limitations.

- Consistent with Articles 37-39 of GDPR, Commerce has appointed an external Data Protection Officer (DPO). Commerce's DPO is based in Hamburg, Germany, and is regularly involved in reviewing and advising on Commerce's data protection practices. A letter of acknowledgement from Commerce's DPO is available here.

- Commerce's Data Processing Agreement (DPA) includes the EU SCCs, as well as other contractual data protections (e.g., technical and organizational security terms), between merchants and Commerce. The DPA limits Commerce's use, disclosure, and retention of data consistent with its role as a processor. The terms of the DPA apply to all Commerce affiliates, and any data transfers between Commerce affiliates are further subject to Commerce's internal Intra-Group Data Transfer Agreement (IGA), which contains substantially the same safeguards as the DPA.

- Commer's adheres to the voluntary EU- US Data Privacy Framework

- Commerce does not transfer any personal data to subprocessors without: (i) a security assessment, (ii) a privacy assessment (iii) assessing the impact of a data transfer review of data transfer impact; (iv) a written data protection agreement that contains substantially the same data protections as those found in our DPA; *and* (v) the SCCs with supplementary technical and organisational security measures (if data might be exported from the EU). Commerce's ISMS and PIMS programs require security, privacy, and transfer reviews of subprocessors prior to onboarding and at regular intervals thereafter. A list of Commerce's current subprocessors is available here.

- Commerce utilizes Google Cloud's US-Central1 region as our primary data storage location, with additional hosting locations available on Google Cloud's Europe-West3 and Australia-SE1 regions. Information about Commerce's data transfer practices can be found in the Commerce International Data Transfers Whitepaper. This whitepaper is updated regularly and contains important information about how Commerce approaches international data transfers and empowers merchants to exert control over their data, privacy preferences, storefront, and response to data subject requests.